S.O.F.T. (Student Org Financial Threat Model)

Dhruv Guda and Owen Kedroski

Original model: October 14, 2026; revised October 21, 2026

S.O.F.T. (Student Org Financial Threat Model)

S.O.F.T. is a team-developed conceptual framework for analyzing student-organization financial workflows. It adapts general threat-modeling ideas to reimbursement requests, officer access, sensitive records, and transaction approval. It does not demonstrate vulnerabilities in any named institution or provider, and no controls were deployed or tested through this project.

PASTA links business objectives, system scope, threats, vulnerabilities, attacks, and risk; LINDDUN focuses on privacy threats; STRIDE provides broad security threat categories. S.O.F.T. narrows the discussion to financial workflows rather than establishing superiority over these methods (LINDDUN, n.d.; Microsoft, n.d.; UcedaVélez, 2026).

Threat Model

Stage 1: Threat Categorization (The Sorting Hat)

Identify threat scenarios, then map each to one or more categories. A threat is a potential harmful event; a weakness enables it; a consequence describes the resulting harm.

- Spoofing + Identity Fraud: An attacker impersonates an authorized officer to request payment. Generative AI may assist impersonation, but no AI-assisted attack was executed or measured in this project.
- Over-Privilege + Operational Exploitation: A former officer retains unnecessary access, or an authorized user misuses their privileges. Access reviews and individual accountability address different parts of this risk.
- Financial Data Interception + Tampering: An attacker reads or alters sensitive request data. Financial forms may contain student identifiers or bank details; exposure could cause privacy harm even if no payment is made.
- Transaction Hijacking + Accountability Failures: An attacker changes a payment destination, or shared identities prevent reviewers from establishing who approved a transaction. Authentication alone does not establish complete non-repudiation.

Stage 2 & 3: Risk Assessment + Risk Triage

Use the project's illustrative 4 x 4 rubric to record likelihood, impact, rationale, and uncertainty for each scenario. Scores support prioritization; they are not measured event probabilities.

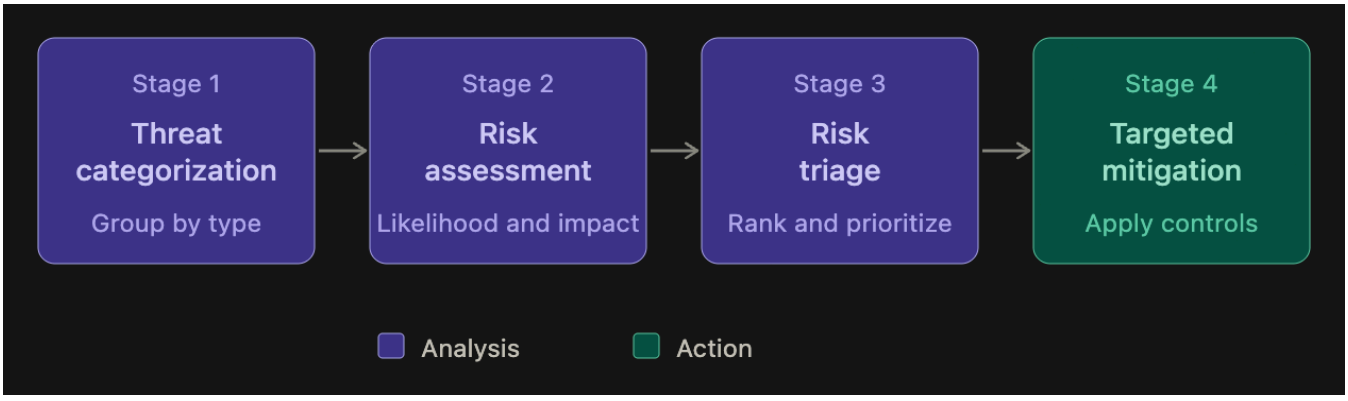
- Assessment: Assign likelihood from 1 (Rare) to 4 (Probable), and impact from 1 (Negligible) to 4 (Catastrophic). The worked example below uses an assumed 12-month planning horizon. The terms and thresholds are project-defined, not prescribed by STRIDE, PASTA, or LINDDUN.
- Triage: Multiply likelihood by impact. Scores 1-3 are Low, 4-7 Moderate, 8-11 High, and 12-16 Critical. Review Critical scenarios first, then High, then Moderate and Low. Actual response deadlines and risk acceptance require an authorized owner; a numeric score alone does not mandate a deadline.

Stage 4: Targeted Mitigation (Applying the Fix)

Select layered controls that address the scenario's causes and consequences. Categories suggest useful questions; they do not restrict mitigation to a single control type.

- For Spoofing + Identity Fraud: Independently verify requests through a previously established contact channel, use phishing-resistant MFA where available, and require separate approval for sensitive changes. A phone call or familiar voice alone does not defeat AI impersonation.
- For Over-Privilege + Operational Exploitation: Use individual identities, least privilege, prompt access revocation when roles change, and periodic access reviews. Separate requesting, approval, and payment responsibilities where practical.
- For Financial Data Interception + Tampering: Use approved secure submission channels, encryption, access restrictions, retention limits, and change records. Encryption alone does not prevent an authorized user from altering a request.
- For Transaction Hijacking + Accountability Failures: Require individual authentication, independent approval of payment changes, protected audit records, and transaction reconciliation. Preserve evidence linking each decision to an accountable person.

Visual Workflow



Conceptual Application

The model organizes financial-workflow scenarios into categories, assessment, triage, and proposed treatment. Its intended benefit is a repeatable discussion of threats, assumptions, and control choices. No implementation, usability study, comparative benchmark, or measured risk reduction is claimed.

Distinctive Features

The model makes three design choices for a narrow educational use case:

- Uses financial-workflow examples that student organizations can discuss without publishing actual account details.
- Combines broad threat categories with explicit scoring assumptions and proposed treatment decisions.
- Uses a project-defined 4 x 4 matrix; interoperability with other frameworks has not been demonstrated.

Discussion

Scenario Analysis

Hypothetical event: An outsider impersonates an officer and submits a fabricated reimbursement request with a changed payment destination. If reviewers rely on the submitted message without independent approval, a fraudulent payment could result. This is a modeled scenario, not evidence that an actual institution's checks were bypassed.

Scope: The model covers organizational roles, data handling, approvals, and payment workflows. Applying it to a wider business would require additional asset mapping, system architecture, threat coverage, and validation. Its effectiveness outside this educational example is unknown.

Shortcomings

Scope limitation: Network availability, hosting infrastructure, and software implementation weaknesses need additional analysis. The four-stage process diagram illustrates a method; it does not identify system trust boundaries.

Insider threats and collusion: Authorized actors can misuse legitimate access or cooperate to bypass separation of duties. Independent approval, reconciliation, and protected logging are relevant proposals; their effectiveness must be tested.

Innovation and Tradeoffs

The project applies established threat-modeling concepts to a narrow financial-workflow example. The tradeoff is simplicity versus coverage. Team credit is shared by Dhruv Guda and Owen Kedroski; this public version does not attribute unverified individual contributions.

Scoring Definitions and Worked Example

Likelihood over the assumed 12-month horizon: 1 Rare - several exceptional conditions required; 2 Unlikely - plausible but substantial barriers remain; 3 Possible - a credible path exists under the stated assumptions; 4 Probable - repeated opportunities and weak barriers are assumed. These qualitative terms do not claim numerical frequencies.

Impact: 1 Negligible - limited inconvenience without material sensitive-data exposure; 2 Marginal - contained loss or disruption; 3 Critical - material financial loss or sensitive-data exposure; 4 Catastrophic - severe or prolonged loss of essential operations, funds, or sensitive information. Actual thresholds require the organization's agreement.

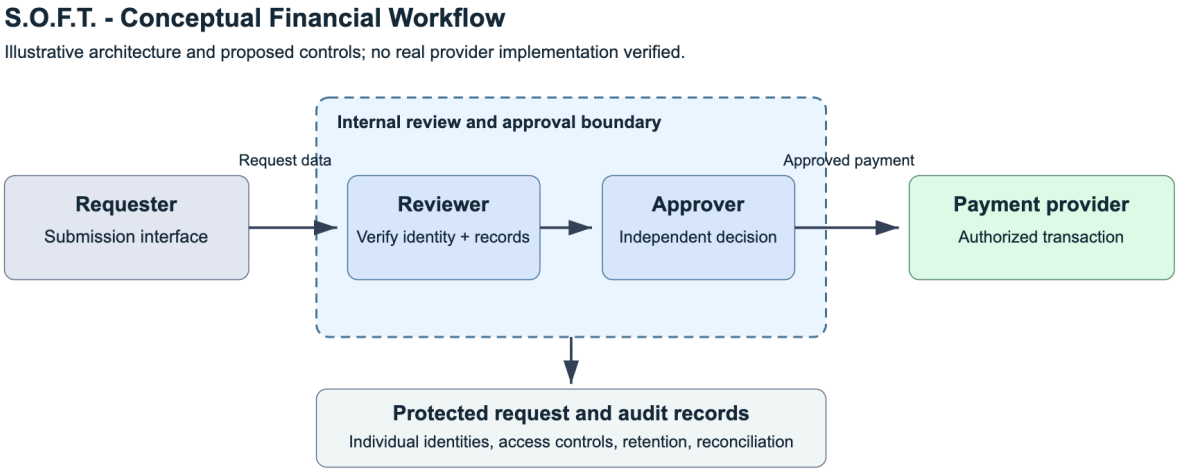
Worked example (illustrative only): An outsider impersonates an officer. The asset is reimbursement funds and payment-destination data. The assumed weakness is approval based on a message without independently verified identity. Likelihood 3 reflects a credible impersonation path under that assumption; impact 3 reflects a potentially material unauthorized payment. Initial score: 3 x 3 = 9 (High).

Proposed controls: Independently verify payment changes using an established contact channel, require a second approver, use individual accounts, and preserve an audit trail. Suggested accountable role: finance officer with an independent approver; these are proposed roles, not verified appointments.

Assuming these controls are correctly implemented, likelihood might fall to 2 while impact remains 3: modeled residual score 2 x 3 = 6 (Moderate). This estimate is not measured improvement. Validation would require authorized tests of rejected unauthorized changes, access revocation, approval separation, and audit completeness. The owner would then reassess or explicitly accept remaining risk.

Conceptual System and Trust Boundaries

The accompanying diagram is an illustrative system model, not a verified architecture. Boundary 1 separates the requester and submission interface from internal reviewers. Boundary 2 separates review and approval from the payment provider. Sensitive request data and audit records require access control throughout.



References

LINDDUN. (n.d.). *LINDDUN: Privacy threat modeling*. https://linddun.org/

Microsoft. (n.d.). *Design secure applications on Azure*. Microsoft Learn. https://learn.microsoft.com/en-us/azure/security/develop/secure-design

UcedaVélez, T. (2026, September 10). *Understanding PASTA threat modeling*. VerSprite. https://versprite.com/resources/blog/understanding-7-stages-pasta-threat-modeling/